



EXECUTIVE SUMMARY & OBJECTIVES

ISSUE: Presently, U.S. critical infrastructure operators are facing multiple threats from various foreign cyber-criminal groups. In particular, the water sector has been the target of a strategic prepositioning effort, where a state-sponsored APT designated “PESTIS” infiltrated IT and OT networks. Although currently dormant, the C2 system could be activated at any moment to begin causing severe disruptions and damage. Simultaneously, a new class of ransomware known as “RUGRAT” is targeting multiple sectors and large businesses. Although these two operations are believed to be run by separate entities, a proxy connection cannot be ruled out at this time.

OBJECTIVE: The NSC is being asked to initiate cross-agency responses to rapidly stabilize critical infrastructure, protect cyberspace, and reduce escalation risks. The aim of these responses is as follows: Establish a map of victims, understand attacker capabilities and infrastructure, strategize and execute surgical disruption operations, implement long-term regulation changes to address legacy system vulnerabilities, and formalize the roles of private sector cyber auxiliaries.

KEY SECURITY CONCERNS

1	RISK: State-backed adversarial pre-positioning in the water sector and critical municipality operations. IMPACT: Threat of service disruption, environmental damage, and health risks.	NCISS SCORE: MEDIUM
2	RISK: Cascading failures across industries due to water sector vulnerabilities and sector interdependence. IMPACT: Degraded service impacts business consumers such as power generation, manufacturing, and data centers.	
3	RISK: The Ransomware-as-a-Service ecosystem and new RUGRAT campaign. IMPACT: Financial losses and lowered public trust, use of shared TTP’s severely complicate attribution.	

POLICY OPTIONS & ADVISED ACTIONS

The following plan-of-action options are being proposed. Depending on how the situation escalates, the NSC is advised to choose policies and actions according to new developments within acceptable risk tolerances.

PHASE 1: CONTINUED INTEL COLLECTION	PHASE 2: INTEL VALIDATION & INFO BRIDGING
The NSC should <u>convene an interagency task force that includes the FBI, CISA, and the EPA</u> to oversee policy execution. The NSC should <u>authorize the pursuit of the Rule 41 Amended Warrant</u> under the FBI, on the <u>strict condition that the use of the warrant is scoped to operations that map infrastructure</u> that has been infected by PESTIS, under the supervision of the DOJ. Simultaneously, the FBI and Treasury will <u>trace RUGRAT Bitcoin wallets</u> and identify cash-out points to aid attribution. Finally, a confidential <u>TLP:RED advisory</u> will be issued to E-ISAC and MFG-ISAC, advising at-risk members take a “shields-up” stance and remain vigilant for anomalous behaviors.	Phase trigger: An initial victim map becomes available. In order to bridge intelligence gaps with the private sector, the <u>NSC should authorize ODNI to declassify technical IOC’s of PESTIS</u> . This intel should be <u>shared with cloud providers</u> , and in return, they will be <u>expected to share detections of PESTIS activity</u> in order to aid investigations. <u>DOJ must direct these providers to preserve adversary-controlled systems for forensic analysis and refrain from performing disruptive actions without federal coordination</u> . The Rule 41 Amended Warrant scope can be expanded to <u>task domestic ISPs with voluntary monitoring</u> of traffic to known C2 domains.
Pros: Low-risk, maintains operational security. Cons: Does not halt malicious activity, non-intrusive limitations. Stakeholders: DOJ, CISA, EPA, FBI, NSC, Treasury, E/MFG-ISAC.	Pros: Low-risk, build a foundation for future active disruptions. Cons: Legal friction, risk of inadvertently alerting the actor. Stakeholders: ODNI, DOJ, FBI, Cloud providers, ISP’s.
PHASE 3: DISRUPTION & DEFENSES	PHASE 4: REGULATORY REFORMS
Phase trigger: Confirmed shift to aggressive behavior by adversary. Using intel gathered from Phase 2, and <u>after conducting an impact analysis</u> , the NSC may <u>authorize Rule 41 Amended Warrant scope expansion to include takedown and seizure operations</u> , on the condition that <u>such actions would not cause severe disruptions to critical domestic operations</u> . Disruption actions will be designed to preserve attribution ambiguity and <u>minimize interstate escalation risk</u> . Meanwhile, high-risk and confirmed victim municipalities will be <u>directed by the EPA to fully air-gap OT systems and revert to manual operation where safe and operationally feasible</u> . DHS Public Affairs will <u>deliver strategic communications to congress and state leaders</u> regarding this situation in order to <u>quell fears regarding overreach</u> .	Phase trigger: Post-resolution of active threats. In the long term, after this situation is resolved, <u>new regulations to address the vulnerabilities present in legacy systems</u> will be needed. Once a situational review can be completed and applicable cyber kill-chains have been documented, the <u>government may opt to introduce new regulatory frameworks and minimum security baselines for critical sectors</u> . ONCD and Congress may also <u>establish legislation for future cases where private intervention is necessary</u> to carry out public ‘active defense’ operations. This would allow for more <u>formal, information-sharing relationships</u> to be formed with the industry, which would <u>professionalize their role within national cyber defense</u> .
Pros: Directly severs adversary access and addresses public concern. Cons: Medium-risk of further situation escalation/collateral damage. Stakeholders: CISA, DHS, EPA, FBI, WaterISAC, Municipalities.	Pros: Clarifies legal standards, addresses systemic vulnerabilities. Cons: High-risk of substantial economic and political burdens. Stakeholders: Congress, EPA, ONCD, Industries.

Color legend:

[Green] - Low risk

[Yellow] - Medium risk

[Red] - High risk